

LAB FIREWALL TRONG CENTOS

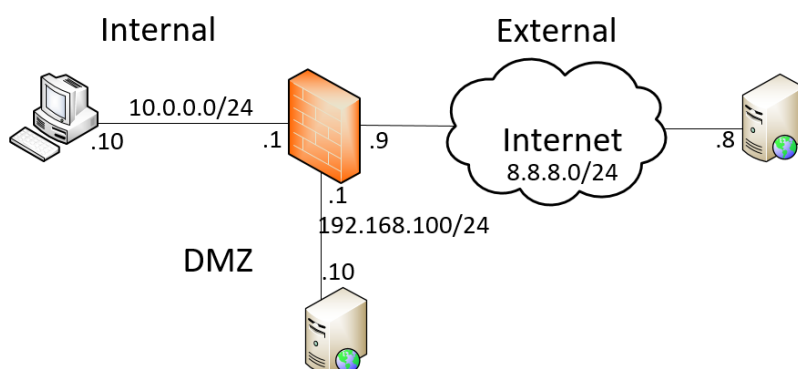
Xây dựng mô hình tường lửa 3 chân (3-leg) gồm các vùng `external` (Internet), `internal` (mạng nội bộ) và `dmz` (khu phi quân sự).

Xây dựng một hệ thống tường lửa hoàn chỉnh cho doanh nghiệp với các yêu cầu:

- **Máy chủ tường lửa (Firewall):** Sử dụng Linux với `firewalld`, có 3 card mạng.
- **Vùng External (WAN/Internet):** Kết nối ra ngoài, sử dụng tính năng giả mạo địa chỉ (`masquerade`) để các máy trong mạng internal và DMZ có thể truy cập Internet .
- **Vùng Internal (LAN):** Khu vực dành cho máy tính nhân viên, được phép ra Internet và truy cập có giới hạn vào DMZ .
- **Vùng DMZ:** Khu vực dành cho máy chủ Web (public), được phép ra Internet nhưng không được phép truy cập ngược lại vào mạng Internal .
- **NAT (Port Forwarding):** Cho phép người dùng Internet truy cập vào trang web đặt trong DMZ thông qua địa chỉ public của tường lửa .

Phần 1: Chuẩn bị mô hình

Sơ đồ mạng



Kiến trúc hệ thống

- **Máy chủ Firewall:**
 - HĐH: Rocky Linux / AlmaLinux / CentOS Stream 9 (hoặc bất kỳ distro nào có `firewalld`).
 - **eth0 (external):** Gán IP động (DHCP) hoặc IP tĩnh public (ví dụ `203.0.113.10/24`) để kết nối ra Internet. Đây là vùng không tin cậy .
 - **eth1 (dmz):** IP `192.168.100.1/24`. Kết nối vào switch/chung mạng với máy chủ Web.
 - **eth2 (internal):** IP `10.0.0.1/24`. Kết nối vào switch/chung mạng với máy Client.
- **Máy chủ DMZ (Web Server):**
 - HĐH: Linux hoặc Windows.
 - IP: `192.168.100.10/24`.

- Gateway: 192.168.100.1 (địa chỉ firewall).
- Cài đặt và chạy dịch vụ Web (HTTP/HTTPS).
- **Máy trạm Internal (Client):**
 - HĐH: Windows hoặc Linux.
 - IP: 10.0.0.10/24.
 - Gateway: 10.0.0.1 (địa chỉ firewall).
 - DNS: 8.8.8.8 hoặc DNS của công ty.

Phần 2: Các bước thực hiện chi tiết

Bước 1: Khởi tạo cấu hình mạng trên Firewall

1. **Cấu hình IP tĩnh cho các card mạng.** Tạo các file cấu hình trong `/etc/sysconfig/network-scripts/` (RHEL/CentOS 8/9) hoặc sử dụng Netplan (Ubuntu) / nmcli. Đảm bảo các interface đã được gán đúng IP.
2. **Kích hoạt IP Forwarding** để cho phép chuyển tiếp gói tin giữa các card mạng:

```
# Sửa file sysctl
echo "net.ipv4.ip_forward = 1" >> /etc/sysctl.conf
# Áp dụng ngay Lập tức
sysctl -p
```

Giải thích: Dòng lệnh này bật tính năng chuyển tiếp gói tin IP, biến máy chủ Linux thành một router thực thụ, cho phép nó chuyển dữ liệu giữa mạng Internal, DMZ và External .

Bước 2: Cấu hình firewalld zones

firewalld sử dụng các "vùng" (zones) để phân loại mức độ tin cậy. Chúng ta sẽ gán mỗi card mạng vào một zone phù hợp .

1. **Xác định zone mặc định và các zone có sẵn:**

```
firewall-cmd --get-default-zone
firewall-cmd --get-zones
```

2. **Gán interface vào zone tương ứng:**

```
# Gán eth0 (ra Internet) vào zone 'external'
firewall-cmd --zone=external --change-interface=ens33 --permanent
# Gán eth1 (DMZ) vào zone 'dmz'
firewall-cmd --zone=dmz --change-interface=ens36 --permanent
# Gán eth2 (Internal) vào zone 'internal'
firewall-cmd --zone=internal --change-interface=ens37 --permanent
```

3. **Kiểm tra lại:**

```
firewall-cmd --get-active-zones
```

Kết quả sẽ tương tự:

```
external
  interfaces: ens33
dmz
  interfaces: ens36
internal
  interfaces: ens37
```

Bước 3: Cấu hình rule cơ bản cho từng zone

Mỗi zone sẽ có các dịch vụ được phép khác nhau.

1. Zone external (WAN/Internet):

- Zone này mặc định đã bật `masquerade` (giả mạo địa chỉ), cho phép các máy ở internal và DMZ chia sẻ kết nối Internet ra qua `eth0`.
- Chúng ta chỉ nên mở rất ít dịch vụ ở đây (ví dụ: SSH từ một IP quản trị cụ thể - sẽ làm ở bước rich rule sau).
- Không cần thêm service nào, giữ nguyên.

2. Zone dmz (Khu vực máy chủ):

- Cho phép truy cập dịch vụ Web (HTTP, HTTPS) từ bên ngoài vào máy chủ trong DMZ.
- Chặn các máy trong DMZ khởi tạo kết nối về mạng Internal (mục tiêu chính của DMZ).

Cho phép HTTP và HTTPS vào zone dmz

```
firewall-cmd --zone=dmz --add-service=http --permanent
```

```
firewall-cmd --zone=dmz --add-service=https --permanent
```

Có thể cho phép SSH từ internal để quản trị (sẽ cấu hình chính xác hơn ở bước rich rule)

```
# firewall-cmd --zone=dmz --add-service=ssh --permanent
```

Lưu ý về chặn DMZ gọi về Internal: Việc chặn này thường được kiểm soát bởi policy chuyển tiếp (forward) mặc định. Trong `firewalld`, forward giữa các zone được quản lý bởi policy hoặc rich rules. Mặc định, forward có thể được phép. Chúng ta sẽ cấu hình chính xác ở Bước 5.

3. Zone internal (Mạng nội bộ):

- Máy trong internal cần được ra ngoài Internet và có thể cần truy cập vào dịch vụ trong DMZ.
- Cho phép các dịch vụ cơ bản: SSH, truy cập web (để vào DMZ), và các dịch vụ nội bộ khác (nếu có).

Cho phép SSH, HTTP, HTTPS (để truy cập vào web DMZ)

```
firewall-cmd --zone=internal --add-service=ssh --permanent
```

```
firewall-cmd --zone=internal --add-service=http --permanent
```

```
firewall-cmd --zone=internal --add-service=https --permanent
```

Nếu có máy chủ email nội bộ, có thể thêm service khác

4. Áp dụng cấu hình:

```
firewall-cmd --reload
```

Bước 4: Cấu hình NAT (Port Forwarding) - Cho phép Internet truy cập Web trong DMZ

Để người dùng Internet có thể truy cập trang web `http://8.8.8.9` (địa chỉ IP public trên firewall) và nội dung được lấy từ máy chủ web `192.168.100.10` trong DMZ, chúng ta cần cấu hình chuyển tiếp cổng (port forwarding) trên zone `external`.

```
# Thêm rule chuyển tiếp cổng 80 từ external vào máy 192.168.100.10 (cổng 80)
firewall-cmd --zone=external --add-forward-port=port=80:proto=tcp:toaddr=192.168.100.10 --permanent
# Tương tự cho HTTPS (cổng 443) nếu cần
# firewall-cmd --zone=external --add-forward-port=port=443:proto=tcp:toaddr=192.168.100.10 --permanent
# Reload để áp dụng
firewall-cmd --reload
```

Lưu ý: Zone `external` mặc định đã bật `masquerade` (có thể kiểm tra bằng `firewall-cmd --zone=external --query-masquerade`). Nếu chưa bật, cần bật `masquerade` trước khi forward port:

```
firewall-cmd --zone=external --add-masquerade --permanent
```

Bước 5: Cấu hình chính sách chuyển tiếp (Forward Policies) - Cốt lõi của bảo mật DMZ

Đây là bước quan trọng nhất để đảm bảo DMZ hoạt động đúng: **Máy trong DMZ không được phép khởi tạo kết nối vào mạng Internal**. `firewalld` trong các phiên bản mới hỗ trợ cấu hình policy rất linh hoạt.

Mục tiêu:

- Cho phép **Internal** kết nối tới **DMZ** (truy cập web).
- Cho phép **Internal** kết nối ra **External** (ra Internet).
- Cho phép **DMZ** kết nối ra **External** (để máy chủ web update, v.v.).
- **Ngăn chặn DMZ** kết nối tới **Internal**.

Có thể cấu hình bằng "rich rules" phức tạp, nhưng cách hiệu quả nhất là sử dụng tính năng **Policy** trong `firewalld` (có trong RHEL/CentOS 8+).

Tạo một policy có tên `block-dmz-to-internal`:

```
# Tạo policy với tên tùy chỉnh (sẽ tạo file /etc/firewalld/policies/block-dmz-to-internal.xml)
firewall-cmd --permanent --new-policy blockDmzToInternal
# Đặt mục tiêu (target) là DROP hoặc REJECT - policy này sẽ áp dụng cho forward từ DMZ đi đâu?
# Chúng ta sẽ chỉ rõ nguồn là dmz và đích là internal
firewall-cmd --permanent --policy blockDmzToInternal --add-ingress-zone dmz
firewall-cmd --permanent --policy blockDmzToInternal --add-egress-zone internal
# Đặt target là REJECT để chặn
firewall-cmd --permanent --policy blockDmzToInternal --set-target REJECT
# Reload
firewall-cmd --reload
```

Với policy này, bất kỳ gói tin nào từ zone **dmz** định đi đến zone **internal** sẽ bị từ chối. Các luồng khác (dmz->external, internal->dmz, internal->external) sẽ được xử lý bởi cơ chế forward mặc định hoặc các policy khác.

Lưu ý cho người mới: Nếu bạn dùng phiên bản **firewalld** cũ hơn, việc kiểm soát forward giữa các zone có thể phức tạp hơn và thường yêu cầu "rich rules". Ví dụ, một rich rule để chặn DMZ gọi về Internal có thể trông như sau:

```
firewall-cmd --zone=dmz --add-rich-rule='rule family="ipv4" destination address="10.0.0.0/24" reject' --permanent
```

Tuy nhiên, cách dùng "policy" như trên là hiện đại và được khuyến nghị.

Bước 6: Cấu hình quản trị từ xa an toàn (Rich Rules - Ví dụ nâng cao)

Giả sử bạn muốn cho phép quản trị viên từ một máy cụ thể trong mạng Internal (ví dụ: 10.0.0.100) SSH vào cả firewall và máy chủ DMZ. Đây là lúc dùng "rich rules" để kiểm soát chi tiết hơn.

Trên firewall:

```
bash
# Cho phép máy 10.0.0.100 SSH vào cổng 22 của chính firewall (dịch vụ quản trị firewall)
firewall-cmd --permanent --zone=internal --add-rich-rule='rule family="ipv4" source address="10.0.0.100/32" service name="ssh" accept'

# Cho phép máy 10.0.0.100 SSH từ internal vào máy chủ DMZ (192.168.100.10) thông qua firewall
# Cần một rule forward phức tạp hơn, nhưng ví dụ đơn giản là bật SSH service trên zone dmz,
# nhưng vì đã có policy chặn dmz->internal, luồng internal->dmz (ssh) vẫn ổn nếu được phép.
# Bước này chỉ cần bật service ssh trên zone dmz:
firewall-cmd --permanent --zone=dmz --add-service=ssh
firewall-cmd --reload
```

Phần 3: Kiểm tra và xác minh

Kiểm tra từng luồng giao tiếp

1. **Từ Client Internal (10.0.0.10):**
 - **Ping ra Internet:** `ping 8.8.8.8` -> **Phải thành công.**
 - **Truy cập Web DMZ:** `curl http://192.168.100.10` -> **Phải thành công** (xem được nội dung trang web).
 - **Ping vào DMZ:** `ping 192.168.100.10` -> Nên thành công (nếu DMZ không chặn ICMP, nhưng trong lab có thể chặn để tăng bảo mật).
2. **Từ Web Server DMZ (192.168.100.10):**
 - **Ping ra Internet:** `ping 8.8.8.8` -> **Phải thành công** (nhờ masquerade).
 - **Ping vào Internal:** `ping 10.0.0.10` -> **Phải thất bại** (Đây là yêu cầu bắt buộc của DMZ). Nếu ping được, cần kiểm tra lại policy đã chặn chưa.
3. **Từ Internet (giả lập bằng một máy khác ngoài mạng):**
 - **Truy cập Web:** Mở trình duyệt, gõ `http://203.0.113.10` -> **Phải thấy** nội dung trang web từ máy DMZ.
 - **Ping vào Firewall:** `ping 203.0.113.10` -> Nên thất bại (vì external zone không cho phép ICMP echo-request).

Xem lại toàn bộ cấu hình

Xem cấu hình tất cả các zone

```
firewall-cmd --list-all-zones
```

Xem các policy đã tạo

```
firewall-cmd --get-policies
```

```
firewall-cmd --policy blockDmzToInternal --list-all
```

Tổng kết

Chúng ta vừa hoàn thành bài lab xây dựng tường lửa 3 chân (3-leg) sử dụng `firewalld`. Mô hình này đáp ứng được các yêu cầu bảo mật cơ bản của một doanh nghiệp:

- **DMZ** được cách ly an toàn khỏi mạng nội bộ.
- Các máy trong DMZ và Internal đều có thể ra Internet.
- Dịch vụ Web được publish ra ngoài thông qua NAT.